Báo cáo:

Detection Engineering Lab

Người thực hiện: Hoàng Quốc Việt.

TP. HCM, 20/03/2026.

MỤC LỤC

1. Giới thiệu 3
2. Kiến trúc 3
   2.1. Tổng quan kiến trúc 3
   2.2. Thành phần chính 3
      2.2.1. Endpoint (Windows + Sysmon) 3
      2.2.2. NXLog 4
      2.2.3. Vector (Log Pipeline) 4
      2.2.4. Splunk (SIEM) 4
      2.2.5. Attack Simulation (Atomic Red Team) 5
3. Quy trình thực hiện 5
   3.1. Bước 1: Attack Simulation 5
   3.2. Bước 2: Log Collection 5
   3.3. Bước 3: Log Ingestion 5
   3.4. Bước 4: Log Analysis 6
   3.5. Bước 5: Detection Development 6
   3.6. Bước 6: Validation 6
   3.7. Bước 7: Visualization 6
4. Detection Use Cases 6
   4.1. PowerShell Encoded Command 6
   4.2. LSASS Dump 8
   4.3. Registry Persistence 9
   4.4. Parent-Child Anomaly 10
5. Dashboard 12
6. Alerting 13
7. Tổng kết 14
   7.1. Kết quả đạt được 14
   7.2. Giá trị 15
   7.3. Hạn chế 15
   7.4. Hướng phát triển 15
   7.5. Kết luận 15

1. Giới thiệu

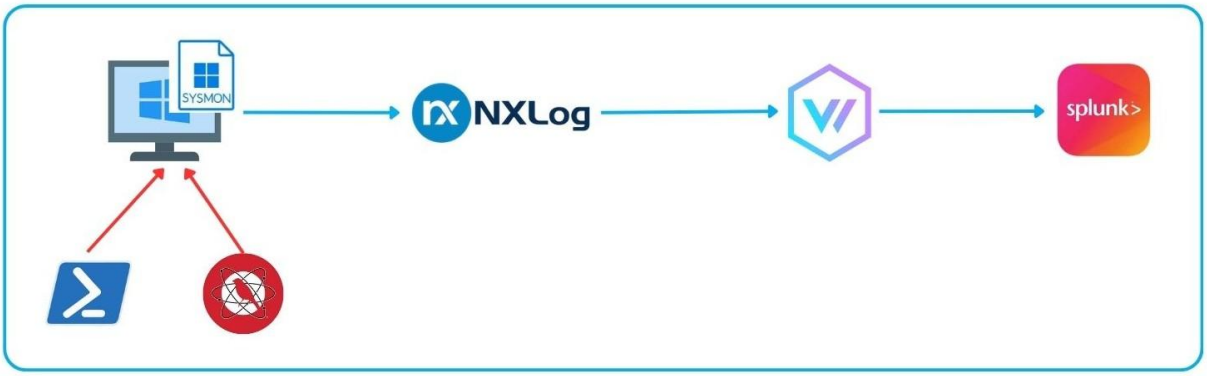
Lab này tập trung vào việc xây dựng năng lực Detection Engineering, cụ thể là:

- Phát hiện hành vi tấn công dựa trên log (behavior-based detection).
- Phân tích log từ endpoint (Sysmon).
- Xây dựng detection rule bằng SPL (Splunk).
- Mapping theo MITRE ATT&CK.
- Triển khai alert và dashboard trong SIEM.

Lab không tập trung vào việc triển khai hạ tầng, mà tập trung vào: Hiểu attacker và phát hiện hành vi của họ.

2. Kiến trúc

2.1. Tổng quan kiến trúc



2.2. Thành phần chính

Hệ thống lab được xây dựng theo mô hình thu thập và xử lý log nhiều lớp, nhằm mô phỏng pipeline thực tế trong môi trường SOC.

2.2.1. Endpoint (Windows + Sysmon)

Endpoint Windows được cấu hình cài đặt Sysmon để ghi nhận các hoạt động chi tiết ở mức hệ thống.

- Vai trò:
  - Thu thập log hành vi ở mức endpoint.
  - Các loại log chính:
    - Process Creation (Event ID 1).
    - Process Access (Event ID 10).

        - Registry Modification (Event ID 13).
- Ý nghĩa: Sysmon cung cấp khả năng quan sát sâu, giúp phát hiện hành vi attacker thay vì chỉ dựa vào log mặc định của Windows.

2.2.2. NXLog

NXLog được sử dụng để thu thập log từ Windows Event Log và chuyển tiếp sang hệ thống xử lý trung gian.

- Vai trò:
    - Thu thập log từ: Microsoft-Windows-Sysmon/Operational.
    - Chuẩn hóa log.
    - Forward log sang Vector.
- Ý nghĩa: NXLog đóng vai trò như một log shipper, giúp tách biệt việc thu thập log khỏi hệ thống phân tích.

2.2.3. Vector (Log Pipeline)

Vector được sử dụng như một lớp xử lý trung gian (log pipeline), giúp kiểm soát và tối ưu việc truyền log.

- Vai trò:
    - Nhận log từ NXLog.
    - Xử lý / transform log (nếu cần).
    - Forward log đến Splunk.
- Ưu điểm:
    - Hiệu năng cao.
    - Dễ mở rộng.
    - Hỗ trợ pipeline linh hoạt.
- Ý nghĩa: Vector giúp mô phỏng kiến trúc production, nơi log thường đi qua nhiều lớp xử lý trước khi đến SIEM.

2.2.4. Splunk (SIEM)

Splunk đóng vai trò là hệ thống SIEM trung tâm trong lab.

- Vai trò:
    - Lưu trữ và index log.
    - Viết detection rule bằng SPL.
    - Tạo alert.
    - Xây dựng dashboard.
- Ứng dụng trong lab:

    - Phân tích log từ Sysmon.
    - Phát hiện hành vi tấn công.
    - Validate detection thông qua alert.

2.2.5. Attack Simulation (Atomic Red Team)

Để tạo dữ liệu kiểm thử thực tế, lab sử dụng cả phương pháp thủ công và công cụ tự động.

- Công cụ: Atomic Red Team.
- Vai trò:
    - Mô phỏng hành vi attacker theo MITRE ATT&CK.
    - Tạo log thực tế để kiểm tra detection.
- Ví dụ:
    - T1059.001 – PowerShell.
    - T1003.001 – LSASS Dump.
    - T1547.001 – Registry Persistence.
- Ý nghĩa: Giúp đảm bảo rằng detection rule không chỉ đúng về lý thuyết mà còn hoạt động hiệu quả trong thực tế.

3. Quy trình thực hiện

3.1. Bước 1: Attack Simulation

Sử dụng:

- Command thủ công.
- Atomic Red Team.

→ Mục tiêu: tạo log thực tế.

3.2. Bước 2: Log Collection

Sysmon ghi lại:

- Process execution.
- Registry modification.
- Process access.

3.3. Bước 3: Log Ingestion

- nxLog gửi lên Vector và Vector gửi lên Splunk qua HEC.

3.4. Bước 4: Log Analysis

Xác định:

- Event ID.
- Field quan trọng (CommandLine, Image, TargetObject).

3.5. Bước 5: Detection Development

- Viết SPL để phát hiện hành vi bất thường.

3.6. Bước 6: Validation

- Chạy lại attack.
- Kiểm tra alert có trigger hay không.

3.7. Bước 7: Visualization

- Xây dựng dashboard.

4. Detection Use Cases

Lab gồm 4 use-case, đại diện cho các giai đoạn tấn công:

Use Case	Technique	Technique
PowerShell Encoded	T1059.001	Execution
LSASS Dump	T1003.001	Credential Access
Registry Persistence	T1547.001	Persistence
Parent-Child Anomaly	T1204.002	Execution

4.1. PowerShell Encoded Command

- Mô tả:
  - Use-case này nhằm phát hiện việc sử dụng PowerShell với tham số -enc (encoded command), một kỹ thuật obfuscation phổ biến giúp attacker che giấu payload và né tránh các cơ chế phát hiện truyền thống.
  - Hành vi này thường xuất hiện trong giai đoạn Execution của cuộc tấn công.
- Mô phỏng tấn công:
  - Thực thi PowerShell với command đã được encode base64.
  - Có thể sử dụng Atomic Red Team để mô phỏng kỹ thuật T1059.001.
- Phân tích log
  - Log source: Sysmon Event ID 1 (Process Create)

- Field quan trọng:
  - CommandLine
  - Image
  - ParentImage

- Logic phát hiện

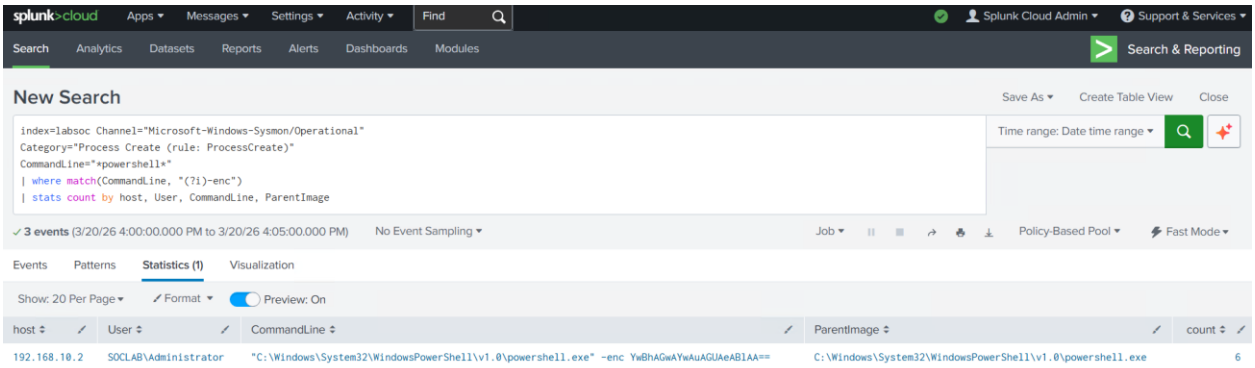
  Detection tập trung vào:

  - Xác định process PowerShell/
  - Kiểm tra sự xuất hiện của tham số -enc trong command-line.

  Đây là dấu hiệu rõ ràng của việc thực thi mã đã được mã hóa.

- SPL Detection

  index=labsoc Channel="Microsoft-Windows-Sysmon/Operational"
  Category="Process Create (rule: ProcessCreate)"
  *CommandLine="*powershell*"*
  | where match(CommandLine, "(?i)-enc")
  | stats count by host, User, CommandLine, ParentImage



- Phân tích: Việc sử dụng -enc hiếm khi xuất hiện trong hoạt động hợp lệ, nhưng lại rất phổ biến trong các kỹ thuật tấn công, đặc biệt là khi attacker muốn tránh bị phát hiện bởi signature-based detection.
- False Positive
  - Script nội bộ.
  - Automation của admin.
- Hạn chế
  - Attacker có thể không sử dụng -enc.
  - Có thể dùng các phương pháp obfuscation khác.
- Cải tiến

- Detect pattern base64 thay vì chỉ tham số.
- Correlate với parent process (Office → PowerShell).

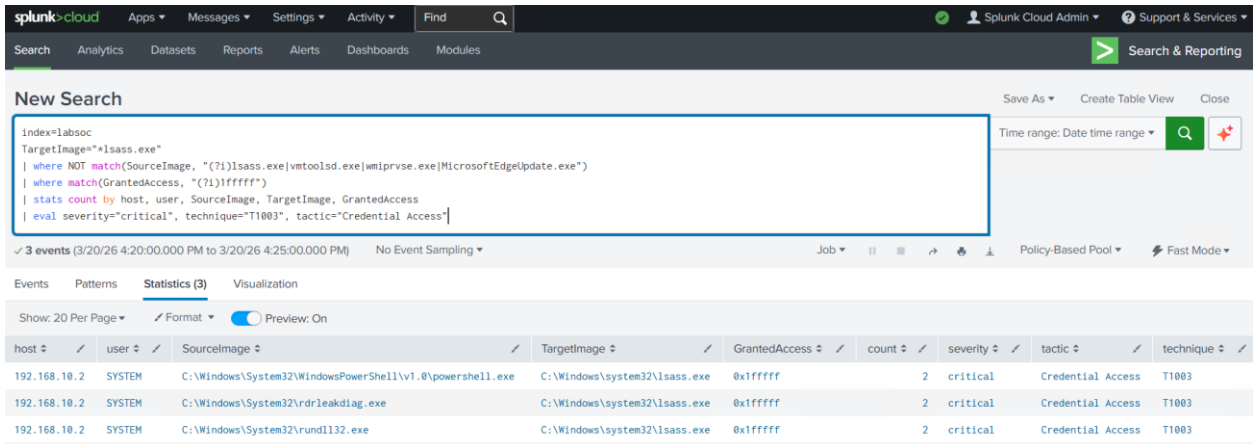
4.2. LSASS Dump

- Mô tả
  - Use-case này nhằm phát hiện hành vi truy cập vào tiến trình lsass.exe, một mục tiêu quan trọng chứa credential của hệ thống.
  - Đây là kỹ thuật điển hình trong giai đoạn Credential Access, thường được thực hiện bởi các công cụ như Mimikatz hoặc ProcDump.
- Mô phỏng tấn công
  - Sử dụng công cụ procdump để dump bộ nhớ của LSASS.
  - Có thể sử dụng Atomic Red Team (T1003.001).
- Phân tích log
  - Log source: Sysmon Event ID 10 (Process Access)
  - Field quan trọng:
    - SourceImage.
    - TargetImage.
    - GrantedAccess.
- Logic phát hiện

  Detection dựa trên:

  - Theo dõi các process truy cập vào lsass.exe.
  - Kiểm tra quyền truy cập cao (0x1fffff).
  - Loại bỏ các process hợp lệ.
- SPL Detection

```
index=labsoc
TargetImage="*lsass.exe"
| where NOT match(SourceImage,
"(?i)lsass.exe|vmtoolsd.exe|wmiprvse.exe|MicrosoftEdgeUpdate.exe")
| where match(GrantedAccess, "(?i)1fffff")
| stats count by host, user, SourceImage, TargetImage, GrantedAccess
| eval severity="critical", technique="T1003", tactic="Credential Access"
```



- Phân tích: LSASS là nơi lưu trữ credential → bất kỳ truy cập bất thường nào đều có giá trị detection rất cao.
- False Positive
  - EDR hoặc antivirus
  - Tool quản trị hệ thống
- Hạn chế
  - Attacker có thể bypass bằng kỹ thuật khác
  - Có thể inject vào process hợp lệ
- Cải tiến
  - Xây dựng whitelist chuẩn
  - Correlate với process creation

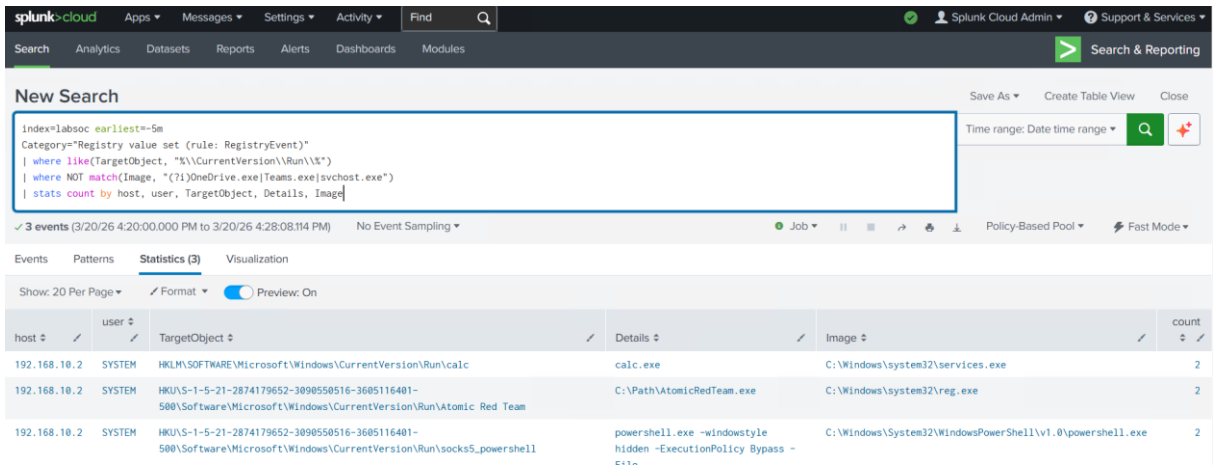
4.3. Registry Persistence

- Mô tả: Use-case này phát hiện việc thay đổi registry Run key — một kỹ thuật persistence phổ biến cho phép attacker thực thi mã khi người dùng đăng nhập.
- Mô phỏng tấn công
  - Thêm một registry key vào: *HKCU\Software\Microsoft\Windows\CurrentVersion\Run.*
  - Có thể sử dụng Atomic Red Team (T1547.001).
- Phân tích log
  - Log source: Sysmon Event ID 13 (Registry Set)
  - Field:
    - TargetObject.
    - Details.
    - Image.
- Logic phát hiện
  - Monitor thay đổi tại Run key

- Phát hiện entry mới được thêm
- Loại bỏ các ứng dụng phổ biến

- SPL Detection

index=labsoc earliest=-5m
Category="Registry value set (rule: RegistryEvent)"
| where like(TargetObject, "%\\CurrentVersion\\Run\\%")
| where NOT match(Image, "(?i)OneDrive.exe|Teams.exe|svchost.exe")
| stats count by host, user, TargetObject, Details, Image



- Phân tích: Run key là một trong những kỹ thuật persistence đơn giản nhưng hiệu quả, được sử dụng rộng rãi bởi attacker.
- False Positive
  - Cài đặt phần mềm hợp lệ.
  - Update ứng dụng.
- Hạn chế
  - Attacker có thể dùng vị trí persistence khác.
  - Có thể chỉnh sửa key có sẵn.
- Cải tiến
  - Baseline registry.
  - Alert theo anomaly (rare value).

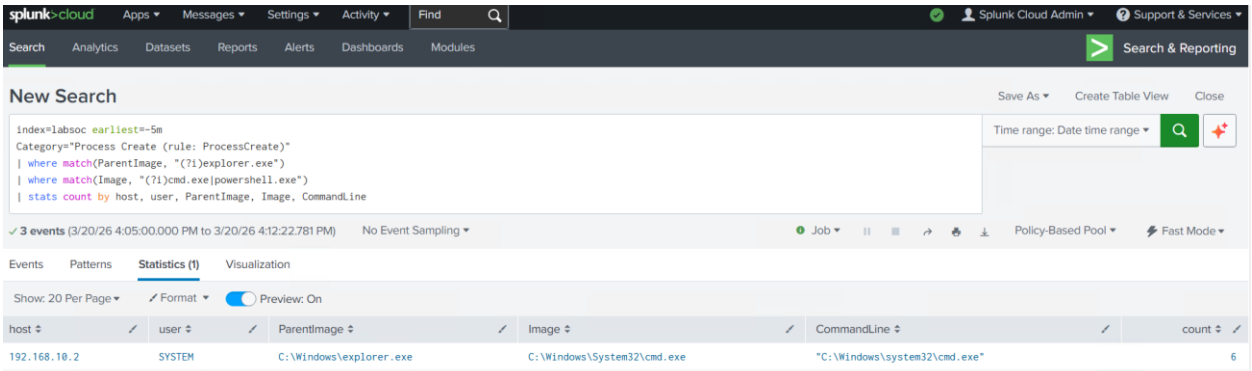
4.4. Parent-Child Anomaly

- Mô tả

- Use-case này phát hiện mối quan hệ bất thường giữa process cha và process con, đặc biệt khi các ứng dụng như Office hoặc Explorer spawn các process dòng lệnh như cmd.exe hoặc powershell.exe.
- Đây là một detection mang tính behavior-based rõ ràng, thường xuất hiện trong các kỹ thuật:
  - Macro-based attack
  - User execution
  - Initial access

- Mô phỏng tấn công: Mở PowerShell hoặc CMD từ Explorer hoặc Run dialog.
- Phân tích log
  - Log source: Sysmon Event ID 1 (Process Create).
  - Field:
    - ParentImage.
    - Image.
    - CommandLine.
- Logic phát hiện
  - Phát hiện process nguy hiểm (cmd.exe, powershell.exe).
  - Kiểm tra parent process bất thường: Word, Excel, Outlook, Explorer.
- SPL Detection

index=labsoc earliest=-5m
Category="Process Create (rule: ProcessCreate)"
| where match(Image, "(?i)powershell.exe|cmd.exe")
| where match(ParentImage, "(?i)winword.exe|excel.exe|outlook.exe|explorer.exe|powershell.exe")
| where NOT match(CommandLine, "(?i)legit_script")
| stats count by host, user, ParentImage, Image, CommandLine

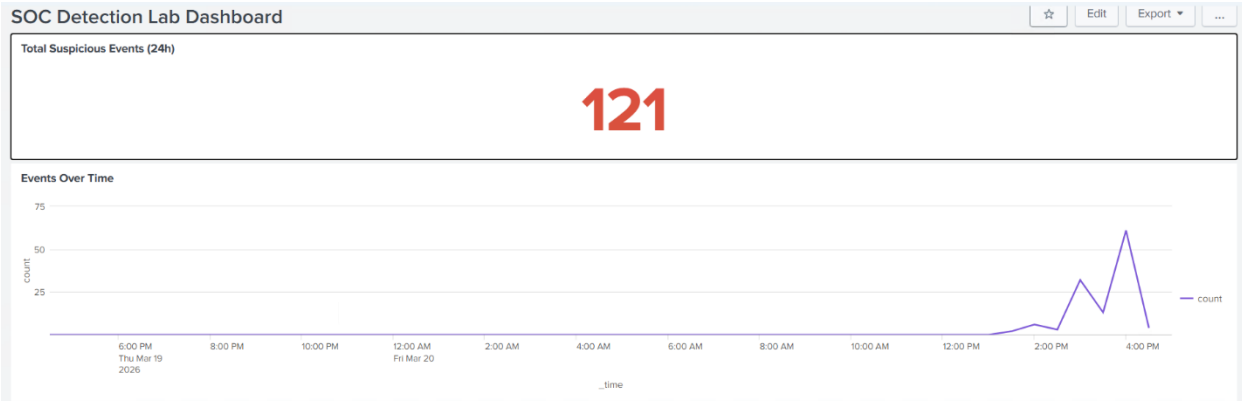


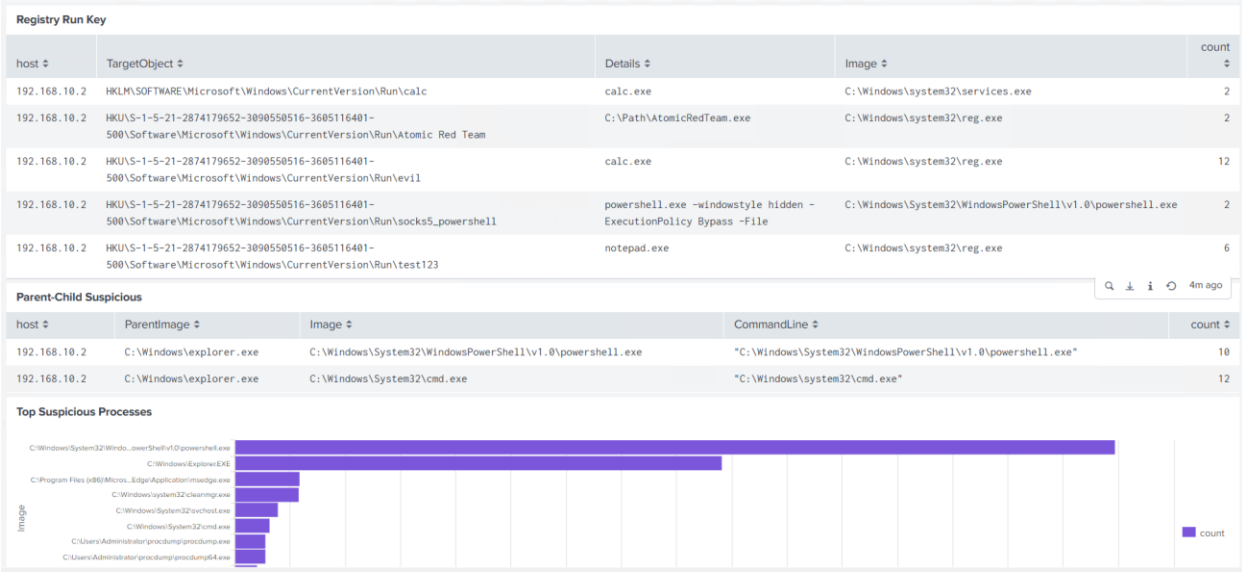
- Phân tích

    - Trong môi trường bình thường:
        - Office application không nên spawn command-line tools.
        - Khi điều này xảy ra → khả năng cao là hành vi đáng nghi.
- Điểm mạnh
    - Behavior-based detection.
    - Không phụ thuộc signature.
    - Bắt được nhiều attack chain thực tế.
- False Positive
    - Người dùng mở cmd từ Run.
    - Admin thao tác.
- Hạn chế
    - Explorer.exe có thể hợp lệ.
    - Thiếu context (file nào spawn).
- Cải tiến
    - Loại bỏ explorer hoặc xử lý riêng.
    - Correlate với network / file activity.

5. Dashboard

- Dashboard được xây dựng để:
    - Tổng hợp alert
    - Hiển thị xu hướng
    - Phân tích hành vi
- Các panel chính:
    - Total alerts (24h)
    - Events over time
    - PowerShell encoded
    - LSASS access
    - Registry persistence
    - Parent-child anomaly
    - Top Suspicious Processes

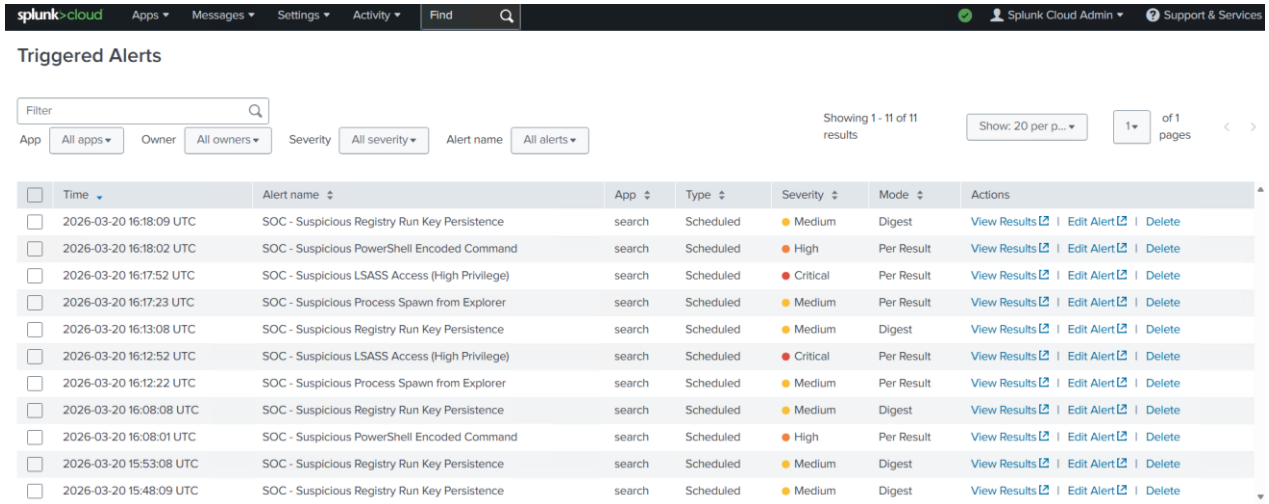




6. Alerting

- Alert được trigger khi: SPL trả về kết quả > 0.
- Frequency: 5 phút.

Title	Actions	Next scheduled time	Owner	App	Sharing	Status
SOC - Suspicious LSASS Access (High Privilege)	Open in search Edit	Mar 20, 2026 9:17:52 AM	sc_admin	search	App	Enabled
SOC - Suspicious PowerShell Encoded Command	Open in search Edit	Mar 20, 2026 9:13:01 AM	sc_admin	search	App	Enabled
SOC - Suspicious Process Spawn from Explorer	Open in search Edit	Mar 20, 2026 9:17:22 AM	sc_admin	search	Private	Enabled
SOC - Suspicious Registry Run Key Persistence	Open in search Edit	Mar 20, 2026 9:13:08 AM	sc_admin	search	App	Enabled



Time	Alert name	App	Type	Severity	Mode	Actions
2026-03-20 16:18:09 UTC	SOC - Suspicious Registry Run Key Persistence	search	Scheduled	Medium	Digest	View Results | Edit Alert | Delete
2026-03-20 16:18:02 UTC	SOC - Suspicious PowerShell Encoded Command	search	Scheduled	High	Per Result	View Results | Edit Alert | Delete
2026-03-20 16:17:52 UTC	SOC - Suspicious LSASS Access (High Privilege)	search	Scheduled	Critical	Per Result	View Results | Edit Alert | Delete
2026-03-20 16:17:23 UTC	SOC - Suspicious Process Spawn from Explorer	search	Scheduled	Medium	Per Result	View Results | Edit Alert | Delete
2026-03-20 16:13:08 UTC	SOC - Suspicious Registry Run Key Persistence	search	Scheduled	Medium	Digest	View Results | Edit Alert | Delete
2026-03-20 16:12:52 UTC	SOC - Suspicious LSASS Access (High Privilege)	search	Scheduled	Critical	Per Result	View Results | Edit Alert | Delete
2026-03-20 16:12:22 UTC	SOC - Suspicious Process Spawn from Explorer	search	Scheduled	Medium	Per Result	View Results | Edit Alert | Delete
2026-03-20 16:08:08 UTC	SOC - Suspicious Registry Run Key Persistence	search	Scheduled	Medium	Digest	View Results | Edit Alert | Delete
2026-03-20 16:08:01 UTC	SOC - Suspicious PowerShell Encoded Command	search	Scheduled	High	Per Result	View Results | Edit Alert | Delete
2026-03-20 15:53:08 UTC	SOC - Suspicious Registry Run Key Persistence	search	Scheduled	Medium	Digest	View Results | Edit Alert | Delete
2026-03-20 15:48:09 UTC	SOC - Suspicious Registry Run Key Persistence	search	Scheduled	Medium	Digest	View Results | Edit Alert | Delete

7. Tổng kết

- Lab này tập trung vào việc xây dựng năng lực **Detection Engineering** thông qua việc mô phỏng và phát hiện các hành vi tấn công phổ biến dựa trên log hệ thống.
- Thông qua việc triển khai pipeline gồm **Sysmon → NXLog → Vector → Splunk**, hệ thống đã mô phỏng tương đối sát với kiến trúc thực tế trong môi trường SOC, từ thu thập log, xử lý, đến phân tích và cảnh báo.

7.1. Kết quả đạt được

Trong quá trình thực hiện, bốn use-case chính đã được xây dựng và kiểm chứng thành công:

- Phát hiện PowerShell encoded command (Execution).
- Phát hiện truy cập trái phép vào LSASS (Credential Access).
- Phát hiện persistence qua Registry Run key (Persistence).
- Phát hiện bất thường trong mối quan hệ parent-child process (Behavior-based detection).

Các detection đều được:

- Mapping theo MITRE ATT&CK.
- Kiểm thử bằng Atomic Red Team.
- Validate thông qua alert trong Splunk.

7.2. Giá trị

Lab không chỉ giúp hiểu cách hoạt động của các công cụ SIEM, mà quan trọng hơn là:

- Hiểu attacker hoạt động như thế nào.
- Biết cách chuyển hành vi → detection logic.
- Xây dựng tư duy behavior-based detection thay vì signature-based.

7.3. Hạn chế

- Detection còn ở mức đơn lẻ, chưa có correlation nhiều bước.
- Chưa tích hợp threat intelligence hoặc enrichment.
- Một số use-case vẫn có khả năng false positive.

7.4. Hướng phát triển

- Xây dựng correlation rule (multi-stage detection).
- Áp dụng baseline và anomaly detection.
- Tích hợp SOAR để tự động hóa phản ứng .
- Cải thiện độ chính xác bằng context enrichment.

7.5. Kết luận

Qua lab này, tôi không chỉ dừng lại ở việc viết query hay dựng dashboard, mà quan trọng hơn là hiểu cách attacker thực sự hoạt động trên hệ thống. Thay vì chỉ nhìn log một cách rời rạc, tôi học được cách:

- Nhìn vào hành vi.
- Đặt câu hỏi "cái này có bình thường không?".
- Và chuyển những hành vi đó thành detection có thể áp dụng trong SIEM.

Các use-case trong lab tuy đơn giản, nhưng phản ánh đúng những kỹ thuật phổ biến ngoài thực tế như execution bằng PowerShell, credential dumping hay persistence qua registry.

Điểm quan trọng nhất tôi rút ra là: Detection không phải là tìm thứ "đã biết", mà là nhận ra điều "bất thường"

Lab này giúp tôi chuyển từ việc xem log sang hiểu và phát hiện hành vi tấn công, và là nền tảng để tiếp tục phát triển theo hướng Detection Engineering trong môi trường thực tế.